

**KESTRELATTICE**

Governed Agent Mesh | Micro-Product

# Hard-Gated Action Approval Flow

The exact approval path for money moves, contract acceptance, and permission changes. A complete, zero-placeholder draft for teams governing AI agents in production: policy gates, audit trails, cost controls, permissioning, and incident response, written so you can adopt it as-is.

---

A complete, ready-to-use governance document. Adopt it as-is, customize the bracketed fields to your environment, and put it to work today.

*Instant delivery | Yours to keep, forever.*

# HARD-GATED ACTION APPROVAL FLOW

For AI Agents in Production Environments Version 1.0 | [EFFECTIVE DATE] Document Owner: [OWNER NAME] | Approval Level: [APPROVAL LEVEL]

## 1. PURPOSE

This document establishes a **multi-layered approval workflow** for AI agent actions in production, ensuring compliance with governance policies, cost controls, and risk mitigation. It applies to all AI agents executing actions that: - Modify production systems - Process sensitive data - Involve financial transactions - Require regulatory adherence - Exceed predefined cost thresholds

Failure to follow this flow may result in **automatic revocation of agent permissions** and escalation to [ESCALATION TEAM].

## 2. SCOPE

### 2.1 In Scope

- All AI agents interacting with:
- Databases (write operations)
- Payment gateways
- User authentication systems
- Third-party APIs with financial/legal implications
- Actions with **cost implications** > [\$COST\_THRESHOLD]
- Changes to **production configurations** (e.g., scaling, environment variables)

### 2.2 Out of Scope

- Read-only queries (unless involving PII)
- Non-production sandbox environments
- Pre-approved automated tasks with **zero human oversight** (see [PRE-APPROVED TASKS LIST])

## 3. APPROVAL HIERARCHY & GATES

The workflow enforces **defensive depth** via sequential approvals. Skipping a gate requires justification in the **Incident Report** ([INCIDENT REPORT FORM]).

| Gate Level      | Approver Role            | Decision Criteria                                                        | Approval Method                       | Time-to-Response | Escalation Threshold |
|-----------------|--------------------------|--------------------------------------------------------------------------|---------------------------------------|------------------|----------------------|
| Gate Pre-Action | 1: [REQUESTER'S MANAGER] | Review of task scope, risk assessment, and cost estimate.                | Digital signature via [APPROVAL TOOL] | [HOURS]          | 48h                  |
| Gate Real-Time  | 2: [SYSTEM OWNER]        | Live validation of agent behavior (e.g., no unauthorized data exposure). | Manual override or auto-approval flag | [MINUTES]        | Immediate            |

| Gate Level       | Approver Role        | Decision Criteria                                                  | Approval Method             | Time-to-Response | Escalation Threshold |
|------------------|----------------------|--------------------------------------------------------------------|-----------------------------|------------------|----------------------|
| Gate Post-Action | 3: [AUDIT TEAM LEAD] | Verification of compliance, cost accuracy, and no adverse effects. | Audit log review + approval | [HOURS]          | 24h                  |

## 4. DETAILED FLOW STEPS

### 4.1 Pre-Action Approval

**Trigger:** Agent request submitted via [REQUEST SUBMISSION TOOL].

1. **Requester** submits:
2. Task description ([TASK DESCRIPTION])
3. Risk assessment ([RISK ASSESSMENT MATRIX])
4. Cost estimate ([COST ESTIMATE])

Data sensitivity classification ([DATA CLASSIFICATION])

[REQUESTER'S MANAGER] reviews and approves/rejects within [HOURS]. Rejection triggers:

7. **Cost override request** (if [COST\_OVERRIDE\_ALLOWED] = Yes)

**Policy violation** (escalates to [COMPLIANCE TEAM])

If approved, the request proceeds to **Gate 2** with a **session token** ([SESSION\_TOKEN]).

### 4.2 Real-Time Validation (Gate 2)

**Trigger:** Agent begins execution.

1. [SYSTEM OWNER] monitors via [MONITORING DASHBOARD] for:
2. Unauthorized data access
3. Cost spikes (> [REAL\_TIME\_COST\_ALERT\_THRESHOLD]%)

Policy violations (e.g., GDPR violations)

**Approval Actions:**

6. **Auto-approve:** If behavior aligns with pre-approval.
7. **Pause:** If anomalies detected (escalates to [SECURITY TEAM]).

**Terminate:** If critical risk (e.g., data breach).

**Audit Trail:** All actions logged in [AUDIT LOG SYSTEM] with timestamps and approver IDs.

### 4.3 Post-Action Review (Gate 3)

**Trigger:** Agent completes task.

1. **[AUDIT TEAM LEAD]** verifies:
2. Cost vs. estimate ([COST\_VS\_ESTIMATE\_TOLERANCE]% allowed).
3. No policy violations ([POLICY\_VIOLATION\_CHECKLIST]).

System stability ([STABILITY\_CHECKLIST]).

#### Approval Outcomes:

6. **Pass:** Task completes; agent retains permissions.

**Fail:** Agent permissions revoked; root cause analysis required.

**Incident Report:** If failures exceed [INCIDENT\_THRESHOLD], escalate to [ESCALATION TEAM].

## 5. COST CONTROLS

- **Predefined Budgets:** Agents must operate within [AGENT\_BUDGET\_LIMIT].
- **Alert Thresholds:**
- **Real-time:** [REAL\_TIME\_COST\_ALERT\_THRESHOLD]% over budget -> pause.
- **Post-action:** [POST\_ACTION\_COST\_TOLERANCE]% over estimate -> audit.
- **Cost Recovery:** Requester reimburses excess costs per [COST\_RECOVERY\_POLICY].

## 6. PERMISSIONING & ACCESS

| Role                  | Permissions                            | Revocation Trigger                         |
|-----------------------|----------------------------------------|--------------------------------------------|
| Requester             | Submit tasks, view approvals           | Repeated policy violations                 |
| [REQUESTER'S MANAGER] | Approve/reject pre-action requests     | Incompetence or negligence                 |
| [SYSTEM OWNER]        | Monitor real-time agent behavior       | Failure to intervene in critical incidents |
| [AUDIT TEAM LEAD]     | Review post-action compliance          | Falsification of audit logs                |
| [ESCALATION TEAM]     | Override all gates, revoke permissions | Catastrophic failure                       |

**Permission Revocation Process:** 1. Triggered by [REVOCATION\_TRIGGER]. 2. Notified via [NOTIFICATION\_CHANNEL]. 3. Temporary hold for [HOLD\_PERIOD] before permanent revocation.

## 7. INCIDENT RESPONSE

**Incident Definition:** Any deviation from the approval flow or policy violation.

| Severity | Response Time | Escalation Path                      | Documentation Required                  |
|----------|---------------|--------------------------------------|-----------------------------------------|
| Critical | Immediate     | [ESCALATION_TEAM] -> [SECURITY_TEAM] | [INCIDENT_REPORT_FORM] + [FORensic_LOG] |
| High     | [HOURS]       | [SYSTEM_OWNER] -> [AUDIT_TEAM_LEAD]  | [POST_MORTEM_REPORT]                    |

| Severity | Response Time | Escalation Path       | Documentation Required     |
|----------|---------------|-----------------------|----------------------------|
| Low      | [HOURS]       | [REQUESTER'S MANAGER] | [LESSONS LEARNED DOCUMENT] |

**Root Cause Analysis (RCA) Required For:** - Repeated incidents (> [INCIDENT\_REPEAT\_THRESHOLD]). - Cost overruns (> [COST\_OVERRUN\_THRESHOLD]).

## 8. AUDIT TRAIL REQUIREMENTS

All actions must be logged with: - **Timestamp:** [AUDIT\_TIMESTAMP\_FORMAT]. - **Approver ID:** [APPROVER\_ID]. - **Agent Action:** [ACTION\_DESCRIPTION]. - **Cost:** [COST\_LOGGED]. - **Data Sensitivity:** [DATA\_SENSITIVITY\_LEVEL].

**Retention Period:** [RETENTION\_PERIOD] (complies with [REGULATORY\_STANDARD]).

## 9. ADOPTION NOTES

### 9.1 Buyer-Fillable Fields Documentation

Every [BRACKETED CAPS] field must be populated as follows: | **Field** | **Documentation** | **Owner** |  
 -----|-----|-----|  
 -----| | [EFFECTIVE DATE] | Date this policy becomes active. | [POLICY\_OWNER] | | [OWNER NAME] |  
 Primary contact for this document. | [TEAM LEAD] | | [APPROVAL LEVEL] | Highest approval authority  
 (e.g., "Director"). | [COMPLIANCE TEAM] | | [REQUESTER'S MANAGER] | Role title (e.g., "Team  
 Lead, AI Governance"). | [ORGANIZATIONAL CHART] | | [SYSTEM OWNER] | Owner of the system  
 the agent interacts with. | [SYSTEM DOCUMENTATION] | | [AUDIT TEAM LEAD] | Lead responsible  
 for post-action reviews. | [AUDIT PROCEDURES] | | [ESCALATION TEAM] | Emergency contact for  
 critical incidents. | [INCIDENT RESPONSE PLAN] | | [REQUEST SUBMISSION TOOL] | Tool used to  
 submit agent requests (e.g., "ServiceNow"). | [IT INFRASTRUCTURE] | | [APPROVAL TOOL] | Tool for  
 digital signatures (e.g., "DocuSign"). | [SECURITY POLICY] | | [MONITORING DASHBOARD] |  
 Real-time monitoring interface. | [OBSERVABILITY DOCS] | | [AUDIT LOG SYSTEM] | System storing  
 approval logs (e.g., "Splunk"). | [DATA GOVERNANCE] | | [INCIDENT\_REPORT\_FORM] | Form for  
 documenting incidents. | [RISK MANAGEMENT] | | [FORENSIC LOG] | Detailed logs for critical  
 incidents. | [SECURITY TEAM] | | [POST\_MORTEM\_REPORT] | Document for analyzing incidents. |  
 [PROCESS IMPROVEMENT] | | [LESSONS\_LEARNED\_DOCUMENT] | Summary of low-severity  
 incidents. | [KNOWLEDGE BASE] | | [REVOCATION\_TRIGGER] | Conditions for permission revocation  
 (e.g., "3 violations"). | [ACCESS CONTROL POLICY] | | [NOTIFICATION\_CHANNEL] | Method for  
 incident alerts (e.g., "Slack #ai-alerts"). | [COMMUNICATIONS PLAN] | | [AGENT\_BUDGET\_LIMIT] |  
 Maximum allowed cost per agent session. | [FINANCE TEAM] | |  
 [REAL\_TIME\_COST\_ALERT\_THRESHOLD] | % over budget to trigger pause. | [COST CONTROL  
 POLICY] | | [POST\_ACTION\_COST\_TOLERANCE] | % over estimate allowed before audit. |  
 [ACCOUNTING STANDARDS] | | [INCIDENT\_THRESHOLD] | Number of incidents to trigger RCA. |  
 [RISK APPETITE DOC] | | [INCIDENT\_RE

# KESTRELATTICE

The governed agent mesh for production AI.

[kestrelattice.com](https://kestrelattice.com)